Security and Compliance

Use **VCF Operations** as a VI administrator to evaluate the security stance of your organization across the VCF fleet. Compliance management continuously monitors your infrastructure against industry standards and custom policies. It detects violations, highlights risk areas, and provides actionable remediation recommendations.

In This Chapter

- Monitoring Security Operations
- Viewing and Configuring Compliance
- Security Posture Management
- Audit Records and Audit Trail

Security Hardening and Compliance Guidelines

Review technical security guidance, code samples, and other information for system design, hardening, and compliance work for VCF and vSphere Foundation.

- VMware Cloud Foundation 9.1 Security Configuration Guide
- Regulatory Compliance for VMware Cloud Foundation 9.1

Getting to Know VCF

To apply this documentation, you must be acquainted with the VCF Product Overview, VCF Design, and VCF Release Notes.

SDKs, APIs, and CLI for VCF Administration

You can build, operate, and manage your VCF private cloud by using the VCF SDK and APIs, and VCF PowerCLI. See Administration SDKs, APIs, and CLI.

Monitoring Security Operations

Use VCF security operations to view a consolidated, high-level, strategic view of the VCF fleet's security posture across the VCF platform. VCF security operations help security stakeholders gain enhanced visibility and proactively plan for effective risk management.

What is Security Operations in VCF ?

VCF security operations aims to tackle the challenges associated with security management and it's impact on operations by empowering administrators to proactively manage and improve the security posture of their VCF platform.

The main goals of VCF security operations are:

- Provide timely and accurate information in a centralized location to help you understand and mitigate potential/known security risks.
- Provide comprehensive visibility into security across multiple areas including VMs, ESX hosts, and vSAN.

Where You Find VCF Security Operations

In the VCF Operations navigation bar at the top, click **Protect** and in the left navigation pane, click **Security Operations** to access the **Security Operations** page. The **Security Operations** page provides a holistic view of the organization's infrastructure security stance across the VCF platform.

Infrastructure Security

For an immediate view of the security posture of your VCF platform, you can discover security advisories, host encryption mode, host mode, VM and vSAN cluster encryption, and certificates across VCF Instances. You can also view confidential VM summary and host support for confidential VMs.

Advisories

As part of the infrastructure security view, use the **Advisories** widget to view and access vSphere security advisories. These advisories are categorized by severity such as critical, immediate, or warning so that you can prioritize which ones to address.

To view security advisories, in the VCF Operations navigation bar at the top, click **Protect** and in the left navigation pane, click **Security Operations**. From the **Advisories** widget, click **VIEW DETAILS** for detailed information on diagnostic findings. For more information, see the What are Findings in Diagnostics.

> **Note:**
>
> If there is no data, the **VIEW DETAILS** link is not available.

Host Encryption Mode

Use the **Host Encryption Mode** widget to quickly identify ESX hosts that are not prepared and ready to carry out encryption tasks such as encrypting a VM disk. ESX hosts must be prepared to participate in the security capabilities of the infrastructure.

To view the host's encryption mode, in the VCF Operations navigation bar at the top, click **Protect** and in the left navigation pane, click **Security Operations**. From the **Host Encryption Mode** widget, click **VIEW DETAILS**.

> **Note:**
>
> If there is no data, the **VIEW DETAILS** link is not available.

At the top of the **Host Encryption Mode** page, you see the total number of ESX hosts deployed across the data center. A pie chart displays the encryption modes of the ESX hosts. For information about host encryption modes, see Using Encryption in your vSphere Environment. A list of ESX hosts and their encryption mode status is displayed in a data grid on the page. The host encryption mode status can be incapable, pending incapable, prepared, and safe. You can filter the host encryption mode status using the filter options.

> **Note:**
>
> Status values are displayed in the filters only if at least one of the hosts has that encryption mode status.

Filter

You can filter host encryption modes by the host name, status, and vCenter. Based on your filter, you can view ESX hosts that are incapable, pending incapable, prepared, or safe.

Host Mode

Use the **Host Mode** widget to monitor and track the status of the ESX hosts. Knowing an ESX hosts status is crucial to ensure that adequate levels of security are applied always. The ESX host statuses other than Active, undermines the availability of your infrastructure and could potentially disrupt your production workloads. From this widget, you can discover ESX hosts that are deployed across VCF Instances that require compensating security controls as they are in a non-active mode. You can also discover ESX host maintenance status across the data center.

To view the host's mode, in the VCF Operations navigation bar at the top, click **Protect** and in the left navigation pane, click **Security Operations**. From the **Host Mode** widget, click **VIEW DETAILS**.

> **Note:**
>
> If there is no data, the **VIEW DETAILS** link is not available.

At the top of the **Host Mode** page, you see the total number of ESX hosts deployed across the data center. A pie chart displays the number of hosts in each mode. A list of ESX hosts and their modes is displayed in a data grid on the page. The host modes are quarantine and maintenance, quarantine, in maintenance, and active. You can filter the host modes using the filter options.

Filter

You can filter host modes by the host mode, vCenter server, and host name. Based on the filter you set, you can view ESX hosts in different modes such as active, in quarantine, and in maintenance.

vSAN Cluster Encryption

Use the **vSAN Cluster Encryption** widget for an overview about the encryption status such as encrypted or unencrypted, on different vSAN clusters.

To view vSAN cluster encryption, in the VCF Operations navigation bar at the top, click **Protect** and in the left navigation pane, click **Security Operations**. From the **vSAN Cluster Encryption** widget, click **VIEW DETAILS**. For more details, see Monitoring Storage Operations.

> **Note:**
>
> If there is no data, the **VIEW DETAILS** link is not available.

Certificates

Use the **Certificates** widget for an overview about certificates that require attention that is based on their expiration date. The statuses of certificates are expired, expires in < 30 days, expires in 30-60 days, and active.

To view certificates, in the VCF Operations navigation bar at the top, click **Protect** and in the left navigation pane, click **Security Operations**. From the **Certificates** widget, click **VIEW DETAILS**. For more details, see Managing Certificates in VMware Cloud Foundation.

> **Note:**
>
> If there is no data, the **VIEW DETAILS** link is not available.

VM Encryption

Use the **VM Encryption** widget to find out if your VM workloads are encrypted. You can find details about the storage policy, at per disk level, attached to the VM. If VMs are not encrypted, you should consider encrypting them to avoid data exposure.

To view VM encryption details, in the VCF Operations navigation bar at the top, click **Protect** and in the left navigation pane, click **Security Operations**. From the **VM Encryption** widget, click **VIEW DETAILS**.

> **Note:**
>
> If there is no data, the **VIEW DETAILS** link is not available.

At the top of the **VM Encryption** page, you see the total number of VMs deployed across the data center. A pie chart displays the encryption status of the VMs. Encryption statuses of the VMs could be encrypted, partially encrypted, or unencrypted.

Filter and Data Grid

You can filter VMs by encryption status, vCenter Server name, host name, and VM name. You can view the disk details and storage policy that is attached to each VM by clicking the **VIEW DETAILS** link under the **VM Disk Details** column. This allows you to view the number of disks in the VM and determine whether they are encrypted. For example, if the VM encryption status is partially encrypted and the VM has five disks, you may see that some of the disks are not encrypted and some are encrypted.

Host Support for Confidential VMs

Use the **Host Support for Confidential VMs** widget to see if ESX hosts in the VCF environment support confidential computing. You can drill down to see which VMs in the host have confidential computing that is enabled or disabled. For more information about confidential computing, see Deploy a Confidential vSphere Pod. Using the information in this widget, you can assess the compatibility and availability of hardware on the hosts to support a confidential computing environment and run confidential VMs.

To see which hosts support confidential computing, in the VCF Operations navigation bar at the top, click **Protect** and in the left navigation pane, click **Security Operations**. From the **Host Support for Confidential VMs** widget, click **VIEW DETAILS**.

> **Note:**
>
> If there is no data, the **VIEW DETAILS** link is not available.

At the top of the **Host Support for Confidential VMs** page, you see the total number of hosts that are deployed across the data center. The pie-chart displays whether the hosts have confidential computing that is enabled, disabled, or unsupported.

Filter and Data Grid

You can filter and view data by several parameters such as, ESX host, hardware compatibility for confidential VMs, confidential VM configuration, confidential VM count, and so on.

In the data grid, you can view details such as, the ESX hosts in the VCF environment (ESX host), if the hardware in each ESX host is compatible with confidential computing (hardware compatibility for confidential VMs), if the hardware that supports confidential computing is enabled, disabled, or not applicable (confidential VM configuration), the total number of VMs (total VM count), the number of VMs that support confidential computing (confidential VM count) , and so on.

Confidential VM Summary

Use the **Confidential VM Summary** widget to see if you are running confidential VMs in your VCF environment. The graph displays the number of confidential VMs and non-confidential VMs. For more information about confidential computing, see Deploy a Confidential vSphere Pod.

To see a list of confidential VMs, in the VCF Operations navigation bar at the top, click **Protect** and in the left navigation pane, click **Security Operations**. From the **Confidential VM Summary** widget, click **VIEW DETAILS**.

> **Note:**
>
> If there is no data, the **VIEW DETAILS** link is not available.

At the top of the **Confidential VM Summary** page, you see the total number of VMs deployed.

> **Note:**
>
> The total Confidential VM count that is shown includes registered or powered off VMs. If the host's hardware does not support confidential computing, or confidential computing is disabled on the host, then those confidential VMs on such a host do not start.

A pie-chart displays the number of confidential VMs and non-confidential VMs.

Filter and Data Grid

You can filter and view data by several parameters, such as VM name, VMs that are enabled for confidential computing (confidential VM enabled), guest OS, vCPU count, and so on.

In the data grid, you can view details such as, the list of VMs in the VCF environment, if the VM is enabled for confidential computing, the guest OS details, vCPU count, storage and memory allocated, and so on.

Viewing and Configuring Compliance

VCF Operations helps you visualize the compliance of the objects in your inventory by displaying compliance benchmarks which are measured against a set of standard rules, regulatory best practices, or custom alert definitions. You can discover non-compliant objects and the associated compliance violations and take remedial measures.

Note:

Compliance Benchmarks are deprecated in VCF 9.1 and is replaced by Security Posture Management.

Measuring Compliance of Objects

VCF Operations continuously monitors your infrastructure to ensure that it remains in compliance. Compliance is an ongoing process. VCF Operations evaluates the collected data against the defined policies. It assigns a compliance score to each object or group based on how well they adhere to the policies. The compliance score is typically represented as a percentage.

Note:

Compliance Benchmarks are deprecated in VCF 9.1. Compliance is now managed by Security Posture Management.

How Compliance Benchmarks Work

Compliance is used to monitor the vCenter instances, vSAN, NSX and Cloud Environments. Objects which can be monitored include the hosts, virtual machines, distributed port groups, and distributed switches in your environment. Compliance benchmarks helps to ensure that the settings on your objects meet the defined standards. Score cards help you proactively detect compliance problems in objects manged by VCF Operations. The compliance benchmarks are measured against a set of standard rules, regulatory best practices, or custom alert definitions.

All the compliance standards in VCF Operations, including any standards that you define, are based on alert definitions. Only alert definitions of the Compliance subtype are counted. Custom score cards can monitor user-defined alerts. The alerts and symptom definitions are based on the properties and metrics of the underlying object.

When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications. Depending on the severity of the non-compliance, you can configure automated remediation actions to bring the object back into compliance.

You can manage all compliance related tasks from the **Protect** > **Compliance** page. The data sources are displayed on the top of the page. To see a compliance score card, you must first configure the data source that VCF Operations can monitor, and then activate the benchmarks for those types of data sources. When you activate a benchmark for a data source, you select an applicable policy. VCF Operations then activates the appropriate alert definitions in the policy to measure compliance.

Data Sources for Calculating Compliance

VCF Operations can measure compliance from two data sources to ensure that your virtualized environment adheres to predefined policies and standards. These data sources provide the information necessary to evaluate the compliance of your infrastructure. The data sources that VCF Operations can use for compliance measurement are as follows:

- vCenter
- VCF

Note:

For VCF Operations to measure compliance against these data sources, you must first configure them. See the relevant topic in Integrating Data Sources.

Compliance Benchmarks

VMware SDDC Benchmarks	Displays score cards based on alerts which are measured against the latest hardening guides: • vSphere Security Configuration Guide

- vSAN Security Configuration Guide
- NSX Security Configuration Guide

For more details, see VMware SDDC Benchmark Details.

Note:

In future versions of VCF Operations, these benchmarks will be deprecated. A new, consolidated, out of the box benchmark called, "VCF 9 Security Baseline" will be introduced.

VCF Benchmarks

The VCF Compliance based on VCF Audit Guides score cards are based on alerts for VCF which are measured based on the following:

- VCF 4.2
- VCF 4.3
- VCF 4.4
- VCF 4.5
- CIS Compliance Pack for VCF
- VCF Operations CSA Compliance Pack for VCF.

Note:

In future versions of VCF Operations, these benchmarks will be deprecated. A new, consolidated, out of the box benchmark called, "VCF 9 Security Baseline" will be introduced.

Note:

You must install and activate the Aria Operations CSA Compliance Pack for VCF after downloading the .PAK file from Marketplace.

The alerts are based on objects in your VCF platform.

For more details, see the topic, VCF Benchmarks based on VMware Cloud Foundation Security Baseline.

Custom Benchmarks

Displays benchmarks that you define. Use compliance alerts from integrations, and regulatory management packs, or define your own alerts to monitor. You can define up to five custom score cards. You can import custom benchmarks from other instances of VCF Operations.

Regulatory Benchmarks

Displays benchmarks for industry standard regulatory compliance requirements. You can enable or install compliance packs for the following regulatory standards:

- Defense Information Systems Agency (DISA) Security Standards. This is available from the repository as a native pack.
- The Federal Information Security Management Act (FISMA) Security Standards. This is available from the repository as a native pack.
- Health Insurance Portability and Accountability Act (HIPAA). This is available from the repository as a native pack.
- International Organization for Standardization (ISO) Security Standards. This is available from the repository as a native pack.
- Payment Card Industry Data Security Standard (PCI DSS) Compliance Standards
- CIS Security Standards. Install this pack from the VMware Marketplace.
- NIST SP 800-171, Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations. Install this pack from the VMware Marketplace.
- NIST SP 800-53 R5. Install this pack from the VMware Marketplace.

For more details, see Regulatory Benchmark Details.

Note:

In future versions of VCF Operations, these benchmarks will be deprecated. A new, consolidated, out of the box benchmark called, "VCF 9 Security Baseline" will be introduced.

For instructions on activating these compliance packs, see Activate a Regulatory Benchmark.

VCF Benchmarks based on VMware Cloud Foundation Security Baseline

Security and Compliance for VCF provides guidance for auditors who would want to evaluate their VCF environment. You can leverage the benchmarks and regulatory frameworks available under VCF based on needed benchmarks or regulatory frameworks of your choice.

> **Note:**
>
> Compliance Benchmarks are deprecated in VCF 9.1. Compliance is now managed by Security Posture Management.

VCF Security Baseline

Security Baseline for VCF is a document that builds on top of VCF and leverages security fundamentals. The spreadsheet addresses the most frequently requested compliance standards, regulations, and frameworks.

The security baseline is designed and validated to tailor security configurations without impacting the ability of VCF to meet its design objectives. The security baseline can assist organizations to secure information systems in a compliance context.

The VCF security baseline can be used to evaluate both default and non-default configurations. For more information, see Regulatory Compliance Information on GitHub.

For information about the compliance conditions required for assessing compliance of VCF environments, download the file: VCF Audit Guide.

Versions of the supported VCF security baseline are:

- VCF 4.2
- VCF 4.3
- VCF 4.4
- VCF 4.5

VCF Operations supports the following products for VCF Benchmarks:

- ESX
- SDDC Manager
- vCenter
- vSAN
- NSX

Within these products, VCF Operations can measure the compliance of the following resources:

- VMware Distributed Virtual Switch
- VMware Adapter Instance
- Virtual Machine
- Host System
- Logical Router
- NSX
- NSX Manager Service
- Logical Switch
- Management Cluster
- VCF Adapter Instance
- vSAN
- Data Center
- ESX Cluster

> **Note:**
> Assessment of objects starting from version VCF 4.5 and above is done based on VCF 4.5 security baseline.

Note:

For VCF Operations to measure compliance against these data sources, you must first configure them. See the relevant topic in Integrating Data Sources.

VMware Aria Operations CSA Compliance Pack for VCF

The Cloud Security Alliance (CSA) framework holds significant importance within the sphere of cloud computing, offering comprehensive guidance and best practices for ensuring the security of cloud-based systems and services.

The Aria Operations CSA Compliance Pack for VCF is available as a Management Pack. Before you can enable the Aria Operations CSA Compliance Pack for VCF, you must install and activate the integration. Download the Management Pack from the VMware Marketplace. For information on how to install a management pack, see the topic, Adding and Managing Management Packs from VMware Marketplace.

For more information about the control set, download the file: CSA Controls.

CIS Compliance Pack for VCF

The CIS (Center for Internet Security) Security Standards are a set of best practices and guidelines for securing computer systems and networks. The CIS organization is a non-profit entity that collaborates with experts from various industries to develop and promote consensus-based security configurations and benchmarks.

The supported version is CIS VMware ESXi 8.0 Benchmark v1.1.0 Dated 03-25-2024. For more information about the control set, download the file: CIS for VCF.

VMware SDDC Benchmark Details

VMware Software-Defined Data Center (SDDC) security benchmarks are guidelines or standards that provide recommendations and best practices for securing VMware's SDDC infrastructure. These benchmarks help organizations assess and enhance the security of their virtualized data center environments.

Note:

In future versions of VCF Operations, these benchmarks will be deprecated. A new, consolidated, out of the box benchmark called, "VCF 9 Security Baseline" will be introduced.

Note:

Compliance Benchmarks are deprecated in VCF 9.1. Compliance is now managed by Security Posture Management.

vSphere Security Configuration Guide

For details of the conditions that allow automated compliance assessment and the list of controls that can be used to perform manual checks based on the VMware vSphere 7 Security Configuration Guide Update 3 and VMware vSphere 8 Security Configuration Guide. For more information, download the files:

- vSphere 7 Security Configuration Guide Update 3 .
- vSphere 8 Security Configuration Guide

The vSphere Security Configuration Guide is a comprehensive document provided by VMware that outlines best practices and recommendations for securing VMware vSphere, which is a virtualization platform used for creating and managing virtualized data centers.

The guide covers various aspects of vSphere security and provides configuration guidelines to help administrators protect their vSphere infrastructure from potential threats and vulnerabilities. It addresses security considerations for different components of the vSphere environment, including ESX hosts, vCenter, virtual machines, networking, and storage.

The vSphere Security Configuration Guide typically covers the following areas:

- ESX Host Hardening: It provides recommendations for securing the ESX hosts, including configuring authentication and authorization settings, disabling unnecessary services, enabling security features like Secure Boot and Trusted Platform Module (TPM), and implementing network security measures.
- vCenter Hardening: The guide offers best practices for securing the vCenter, which is a centralized management platform for vSphere. It covers securing the vCenter installation, securing access and authentication, configuring roles and permissions, and enabling auditing and logging.
- Virtual Machine Security: It provides recommendations for securing virtual machines (VMs), such as implementing secure VM configurations, using virtual machine encryption, enabling guest operating system security features, and protecting VMs from unauthorized access.
- Networking Security: The guide offers guidelines for securing the vSphere networking infrastructure, including configuring virtual switches, VLANs, and firewalls, implementing network segmentation, and securing network communication between vSphere components.
- Storage Security: It covers best practices for securing the vSphere storage environment, including securing access to storage devices, implementing storage encryption, and protecting virtual machine data.
- Monitoring and Auditing: The guide emphasizes the importance of monitoring and auditingvSphere components, and provides recommendations for enabling and configuring logging, using security information and event management (SIEM) tools, and monitoring for suspicious activities.

The vSphere Security Configuration Guide is regularly updated by VMware to incorporate the latest security recommendations and considerations. It serves as a valuable resource for administrators seeking to secure their vSphere infrastructure and protect their virtualized environments from potential security risks.

vSAN Security Configuration Guide

The vSAN Security Configuration Guide is a document provided by VMware that offers guidance and best practices for securing vSAN, which is a software-defined storage solution integrated into the vSphere environment.

The guide focuses on helping administrators secure the vSAN infrastructure and protect the data stored within it. It provides recommendations for various security considerations related to vSAN, including authentication, encryption, network security, and access controls.

Here are some key areas covered in the vSAN Security Configuration Guide:

- Authentication and Authorization: The guide provides recommendations for configuring strong authentication mechanisms for vSAN components, such as vCenter and ESX hosts. It suggests using secure protocols, enforcing secure password policies, and implementing multi-factor authentication where possible. It also covers role-based access control (RBAC) and permissions management.
- Encryption: vSAN supports encryption at rest, which ensures that data stored on vSAN disks is protected. The guide offers guidance on configuring vSAN encryption, including selecting the appropriate encryption algorithm, managing key management servers (KMS), and enabling encryption for data at rest.
- Network Security: It provides recommendations for securing network communication within the vSAN environment. This includes using secure protocols, enabling network encryption (VMkernel Encryption), and configuring firewall rules to control network traffic between vSAN components.
- Auditing and Logging: The guide emphasizes the importance of monitoring and auditing vSAN operations. It offers recommendations for enabling and configuring logging, implementing log management solutions, and monitoring vSAN events for potential security incidents.
- Secure Configuration Settings: It provides a list of vSAN-specific configuration settings that can enhance security. This includes recommendations for enabling features like Data-at-Rest Encryption, Secure Erasure, and ensuring proper network configurations.
- Compliance and Hardening: The guide addresses compliance considerations and provides information on how vSAN aligns with various security frameworks, such as the Center for Internet Security (CIS) benchmarks. It also offers recommendations for hardening vSAN components, including ESX hosts and vCenter.

The vSAN Security Configuration Guide is regularly updated by VMware to incorporate the latest security best practices and recommendations. It serves as a valuable resource for administrators who want to ensure the security of their vSAN deployments and safeguard their storage infrastructure and data.

NSX Security Configuration Guide

The VCF Operations Compliance Pack for NSX-T is updated to support the following standards:

- NSX-T 3.2 Security Configuration Guide
- NSX-T 3.1 Security Configuration Guide
- NSX-T 3.0 Security Configuration Guide
- **Note:**
  NSX-T is renamed to NSX.

For more details, download the file: NSX Security Configuration Guide.

The NSX Security Configuration Guide is a comprehensive document provided by VMware that offers guidance and best practices for securing NSX, which is the next-generation network and security platform for software-defined networking.

The NSX Security Configuration Guide focuses on helping administrators secure the NSX infrastructure and protect network traffic, ensuring the confidentiality, integrity, and availability of data. It provides recommendations for various security considerations related to NSX, including authentication, authorization, network security, encryption, and compliance.

Here are some key areas covered in the NSX Security Configuration Guide:

- NSX Component Hardening: The guide provides recommendations for securing NSX components such as NSX nodes, NSX Controllers, and NSX Edge nodes. It includes guidelines for configuring strong authentication, implementing role-based access control (RBAC), and securing administrative access to NSX components.
- Network Security: It covers best practices for implementing network security within NSX. This includes recommendations for creating and managing security groups, implementing distributed firewalling, configuring security policies, and enforcing microsegmentation to control network traffic.
- Authentication and Authorization: The guide offers recommendations for configuring strong authentication mechanisms for NSX, such as integrating with identity providers, enabling multi-factor authentication, and defining access controls based on user roles and permissions.
- Secure Network Communication: It provides guidance for securing network communication within the NSX environment. This includes configuring Transport Layer Security (TLS) encryption for communication between NSX components, securing communication between NSX and vCenter, and protecting east-west and north-south traffic.
- Virtual Machine Security: The guide provides recommendations for securing virtual machines (VMs) deployed in NSX environments. This includes implementing security groups, defining security policies, and leveraging NSX's integration with third-party security solutions for advanced VM protection.
- Logging and Auditing: It emphasizes the importance of logging and auditing in NSX environments. The guide offers recommendations for enabling and configuring logging, integrating NSX with logging and monitoring solutions, and monitoring for security events and anomalies.
- Compliance and Hardening: The guide addresses compliance considerations and provides information on how NSX aligns with various security frameworks and regulations. It also offers recommendations for hardening NSX components and ensuring compliance with security policies.

The NSX Security Configuration Guide is regularly updated by VMware to incorporate the latest security best practices and recommendations. It serves as a valuable resource for administrators who want to ensure the security of their NSX Manager instances across their VCF platform, implement effective network security controls, and protect their software-defined networking infrastructure.

Regulatory Benchmark Details

Regulatory compliance benchmarks are standards or guidelines that help organizations measure and assess their level of compliance with applicable laws, regulations, and industry standards.

Note:

Compliance Benchmarks are deprecated in VCF 9.1. Compliance is now managed by Security Posture Management.

Health Insurance Portability and Accountability Act (HIPAA)

The Health Insurance Portability and Accountability Act (HIPAA) is a U.S. federal law enacted in 1996. HIPAA establishes standards and regulations to protect the privacy, security, and confidentiality of individuals' personal health information (PHI) and electronic health records (EHRs) in the healthcare industry.

The HIPAA Privacy Rule and Security Rule are two key components of the HIPAA standard:

- HIPAA Privacy Rule: The Privacy Rule sets standards for the use and disclosure of PHI by covered entities, which include healthcare providers, health plans, and healthcare clearinghouses. It grants individuals certain rights over their health information, such as the right to access, request amendments, and obtain an accounting of disclosures. Covered entities are required to implement safeguards to protect PHI, provide patients with notice of privacy practices, and obtain written authorization for certain uses and disclosures of PHI.
- HIPAA Security Rule: The Security Rule establishes security standards for protecting electronic PHI (ePHI). It requires covered entities and their business associates to implement administrative, physical, and technical safeguards to ensure the confidentiality, integrity, and availability of ePHI. These safeguards include risk assessments, access controls, encryption, audit controls, disaster recovery plans, and employee training on security awareness.

The HIPAA standard applies to healthcare providers, health plans, healthcare clearinghouses, and their business associates who handle PHI or ePHI. Compliance with HIPAA regulations is mandatory, and non-compliance can result in significant penalties, including financial fines and potential criminal charges.

HIPAA also includes provisions related to the electronic exchange of health information and establishes the Health Information Technology for Economic and Clinical Health (HITECH) Act, which promotes the adoption and meaningful use of electronic health records.

For the control set implemented by HIPAA, download the XLS file: HIPAA Compliance.

Payment Card Industry Data Security Standard (PCI DSS) Compliance Standards

The Payment Card Industry Data Security Standard (PCI DSS) is a set of compliance standards established by the major payment card brands, including Visa, Mastercard, American Express, Discover, and JCB. PCI DSS aims to ensure the security of cardholder data and protect against fraud and unauthorized access within the payment card industry.

The PCI DSS compliance standards consist of twelve high-level requirements, organized into six control objectives. These requirements outline security measures that organizations handling payment card data must implement:

- Build and Maintain a Secure Network
- Protect Cardholder Data
- Maintain a Vulnerability Management Program.
- Maintain an Information Security Policy

PCI DSS compliance requirements vary based on the organization's level of involvement in payment card transactions, classified as levels 1 to 4. Level 1 merchants and service providers with the highest transaction volumes have more stringent requirements and undergo annual on-site audits by a Qualified Security Assessor (QSA). Level 2, 3, and 4 merchants may have different validation requirements, ranging from self-assessment questionnaires (SAQs) to external vulnerability scans.

Compliance with PCI DSS is necessary for entities involved in payment card processing, including merchants, service providers, and payment processors. Non-compliance may result in penalties, fines, increased transaction fees, or restrictions on card acceptance.

It's important to note that while this information provides an overview of the PCI DSS compliance standards, specific requirements and guidance can evolve over time. Therefore, it is recommended to consult the official PCI Security Standards Council (PCI SSC) website and the latest PCI DSS documentation for the most up-to-date information and requirements.

For the control set implemented, download the XLS file: PCI DSS. Currently, Version 4.0 is supported.

CIS (Center for Internet Security) Security Standards

The VMware Aria Operations Compliance Pack for CIS is updated to support the following benchmarks:

- CIS_VMware_ESXi_6.7_Benchmark_V1.3.0

- CIS_VMware_ESXi_7.0_Benchmark_V1.2.0

The CIS (Center for Internet Security) Security Standards are a set of best practices and guidelines for securing computer systems and networks. The CIS organization is a non-profit entity that collaborates with experts from various industries to develop and promote consensus-based security configurations and benchmarks.

The CIS Security Standards include two primary components:

- CIS Controls: The CIS Controls are a set of 20 security actions that organizations can take to mitigate the most common and impactful cyber threats. These controls are prioritized based on their effectiveness in reducing risk. They cover various security domains, including asset management, access control, incident response, network security, and security awareness training. The CIS Controls are regularly updated to address emerging threats and evolving technology landscapes.
- CIS Benchmarks: CIS Benchmarks provide detailed configuration guidelines for securing specific technology platforms and systems. These benchmarks outline recommended settings and configurations for operating systems, applications, and network devices to ensure security and reduce vulnerabilities. CIS Benchmarks are created through a consensus-driven process involving input from cybersecurity experts, vendors, and practitioners.

CIS Security Standards are known for their practical and actionable nature, providing step-by-step instructions and specific configuration recommendations. They are widely adopted across industries and are used as a reference by organizations to assess, improve, and maintain the security of their IT systems and networks.

The CIS organization regularly updates its security standards and benchmarks to address emerging threats, technology advancements, and changes in regulatory requirements. The CIS Security Standards are available to the public, and organizations can leverage them as a valuable resource for enhancing their cybersecurity posture and reducing the risk of cyberattacks.

For the control set implemented, download the file: CIS for VCF.

Defense Information Systems Agency (DISA) Security Standards

The Defense Information Systems Agency (DISA) establishes and provides security standards and guidelines for the U.S. Department of Defense (DoD) and its information systems. DISA is responsible for ensuring the secure operation and defense of DoD's global information infrastructure.

The VMware Aria Operations Compliance Pack for Defense Information Systems Agency (DISA) Security Standards is updated to the following version in VMware Aria Operations 8.18:

- VMware vSphere 7.0 STIG (U_VMW_vSphere_7-0_Y23M07_STIG V1R2 Dated 26 July 2023)
- VMware vSphere 8.0 STIG (U_VMW_vSphere_8-0_Y23M10_STIG Dated 31 October 2023)

DISA has developed several security standards and guidelines to protect sensitive information and ensure the integrity, availability, and confidentiality of DoD systems. Some of the key security standards and guidelines provided by DISA include:

- Security Technical Implementation Guides (STIGs): STIGs are a set of guidelines and configuration standards for various operating systems, applications, and network devices. They provide detailed instructions on how to secure and configure these systems to meet DoD security requirements. STIGs cover a wide range of technologies, including Windows, Linux, Cisco devices, databases, and web servers.
- Security Requirements Guides (SRGs): SRGs are comprehensive documents that outline security requirements for specific technology platforms, systems, or applications. They provide guidance on how to secure and configure systems in accordance with DoD security policies. SRGs address various security domains, including access control, identification and authentication, audit and accountability, and encryption.
- Security Technical Implementation Guides (STIGs) Viewer: DISA provides a STIG Viewer tool that helps organizations assess and implement STIG recommendations. The STIG Viewer automates the process of checking system configurations against STIG requirements, allowing organizations to identify and remediate security vulnerabilities more efficiently.
- Information Assurance Vulnerability Management (IAVM): DISA maintains the IAVM program, which identifies and manages vulnerabilities in DoD systems. IAVM alerts provide timely information about security vulnerabilities and patches. Organizations within the DoD are required to promptly apply these patches to mitigate potential risks.

- DoD Cybersecurity Discipline Implementation Plan (CDIP): The CDIP outlines the implementation and management of cybersecurity practices within the DoD. It provides guidelines and best practices for managing risks, protecting systems, responding to incidents, and fostering a culture of cybersecurity awareness.

DISA's security standards and guidelines play a critical role in ensuring the security and resilience of DoD systems and information assets. They are constantly updated and refined to address emerging threats and align with evolving cybersecurity practices. Organizations within the DoD are expected to adhere to these standards to maintain the security of their systems and networks.

For information about the control set implemented, download the file: DISA.

The Federal Information Security Management Act (FISMA) Security Standards

The Federal Information Security Management Act (FISMA) is a U.S. federal law enacted in 2002. FISMA establishes a framework for securing information systems and managing cybersecurity risks within federal government agencies and their contractors. FISMA requires federal agencies to develop, implement, and maintain information security programs to protect sensitive government information.

While FISMA itself does not provide detailed security standards, it sets requirements for federal agencies to follow certain security guidelines and standards, including those established by the National Institute of Standards and Technology (NIST). NIST Special Publication (SP) 800-53, titled "Security and Privacy Controls for Federal Information Systems and Organizations," is a key document referenced under FISMA.

NIST SP 800-53 provides a catalog of security controls that federal agencies must implement to protect their information systems. The controls cover various areas, including access control, incident response, configuration management, encryption, network security, and security assessment and authorization. The controls are categorized into families and are tailored to address specific security requirements.

FISMA requires federal agencies to develop and maintain a risk-based approach to information security. This involves conducting risk assessments, implementing security controls based on the identified risks, periodically testing and evaluating the effectiveness of these controls, and ensuring continuous monitoring of information systems.

Under FISMA, federal agencies are also required to undergo annual security assessments, including independent audits, to evaluate the effectiveness of their information security programs and controls. The results of these assessments are reported to the Office of Management and Budget (OMB) and Congress.

FISMA compliance is crucial for federal agencies to demonstrate their commitment to protecting government information and ensuring the security of their information systems. It helps establish a standardized approach to information security across federal government entities and aligns with other security frameworks and standards, such as the NIST Cybersecurity Framework and NIST Risk Management Framework.

It's important to note that FISMA requirements may evolve over time, and agencies should refer to the latest guidance provided by NIST and other authoritative sources to ensure compliance with FISMA security standards.

International Organization for Standardization (ISO) Security Standards

The International Organization for Standardization (ISO) is an independent, non-governmental international standardization body that develops and publishes international standards across various industries. ISO has also created a series of security standards specifically related to information security management systems (ISMS). The most well-known among them is ISO/IEC 27001.

ISO/IEC 27001: The ISO/IEC 27001 standard specifies the requirements for establishing, implementing, maintaining, and continuously improving an ISMS within the context of an organization. It provides a systematic and risk-based approach to managing the security of sensitive information. The standard covers areas such as risk assessment, information security policies, asset management, access control, incident management, and compliance. ISO/IEC 27001 is widely adopted by organizations globally and serves as a benchmark for information security management.

ISO/IEC 27002: ISO/IEC 27002 (formerly known as ISO/IEC 17799) is a code of practice for information security controls. It offers guidance and recommendations for implementing security controls and safeguards based on the best practices of information security management. ISO/IEC 27002 covers a broad range of security areas, including organizational security, human resource security, physical and environmental security, communications and operations management, and compliance.

ISO/IEC 27005: ISO/IEC 27005 provides guidelines for conducting risk assessments in the context of information security. It offers a structured approach for identifying, analyzing, evaluating, and treating information security risks. ISO/IEC 27005 helps organizations assess the potential impact of risks, determine risk tolerance, and make informed decisions on implementing appropriate security controls.

ISO/IEC 27017 and ISO/IEC 27018: These standards specifically focus on cloud security. ISO/IEC 27017 provides guidelines for implementing information security controls in cloud computing environments, while ISO/IEC 27018 offers guidance for protecting personal data in the cloud and addresses privacy concerns related to cloud services.

ISO/IEC 27701: This standard is an extension to ISO/IEC 27001 and provides guidelines for implementing a Privacy Information Management System (PIMS). ISO/IEC 27701 helps organizations establish and maintain controls to protect personal data and comply with privacy regulations, such as the General Data Protection Regulation (GDPR).

ISO security standards provide a framework for organizations to establish effective information security management practices. Compliance with these standards demonstrates a commitment to securing sensitive information, managing risks, and implementing robust security controls. Organizations can seek ISO certification through a formal audit process conducted by accredited certification bodies to validate their adherence to ISO security standards.

For information about the control set implemented, download the file: ISO. Currently, version ISO/IEC 27001:2022 is supported.

NIST SP 800-171

NIST Special Publication 800-171, titled “Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations,” provides a set of guidelines developed by the National Institute of Standards and Technology (NIST) to safeguard sensitive federal information residing in nonfederal systems. Specifically aimed at protecting Controlled Unclassified Information (CUI), the framework outlines 14 control families covering areas like access control, incident response, system integrity, and personnel security. It establishes standardized security requirements for contractors, vendors, and partners working with U.S. federal agencies, ensuring that CUI is consistently protected outside government networks. NIST SP 800-171 has become a cornerstone for compliance in industries such as defense, aerospace, and government contracting, often forming the basis for contractual cybersecurity obligations like those found in the DFARS (Defense Federal Acquisition Regulation Supplement).

For information about the control set implemented, download the file:NIST SP 800-171.

NIST SP 800-53 R5

NIST Special Publication 800-53 Revision 5, titled “Security and Privacy Controls for Information Systems and Organizations,” is a comprehensive framework developed by the National Institute of Standards and Technology (NIST) that provides an extensive catalog of security and privacy controls to protect federal information systems and organizations. Unlike NIST SP 800-171, which focuses on Controlled Unclassified Information in nonfederal systems, 800-53 R5 addresses a broader scope, covering federal systems, critical infrastructure, and even private-sector organizations that adopt it voluntarily. It organizes controls into 20 families, ranging from access control and risk assessment to incident response, supply chain protection, and privacy management. Revision 5 modernizes the framework by integrating privacy and security controls, emphasizing flexibility for diverse technologies, and reinforcing supply chain and system resilience. This publication plays a central role in federal cybersecurity strategy, forming the foundation for risk management frameworks like NIST RMF (Risk Management Framework).

For information about the control set implemented, download the file: NISTSP 800-53.

Compliance Score Cards

The compliance page in VCF Operations displays score cards for each type of benchmark. A score card is a compliance visualization term.

> **Note:**
>
> Compliance Benchmarks are deprecated in VCF 9.1. Compliance is now managed by Security Posture Management.

What is a Compliance Score Card

Score cards in the Compliance landing page display the number of non-compliant objects, and the total number of objects affected by each hardening guide. A compliance score is displayed, which is counted as the ratio of compliant objects to total number of objects assessed by the given benchmark, represented in percentage. In addition, you can see the breakdown of the total number of objects that are compliant and non-compliant. You can click a score card to see more details, including alerts that were triggered based on the compliance standards.

The compliance score card of an object is counted as the smallest rounded off integer (100*(total number of symptoms triggered on an object/total number of symptoms)).

The compliance score for the object is based on the most critical of the violated standards. The score card displays 100 when all objects are compliant. When an object is non-compliant, the number of non-compliant symptoms are displayed in red and the total number of symptoms in grey.

> **Note:**
> The compliance score for a user with limited object visibility is the same as for a user with complete object visibility. This is because the compliance score is calculated for all objects, irrespective of whether the user has access to the object or not.

Where You Find Compliance Score Cards

You can view score cards for each of the different types of benchmarks in the Compliance page available under **Protect** > **Compliance**.

Compliance Page

In the **Protect** > **Compliance** summary page, VCF Operations monitors compliance for VMware SDDC benchmarks.

VCF Operations displays compliance score cards for the following cards:

- VCF
- vCenter

Score cards are displayed for:

- VMware SDDC Benchmarks (for both data sources)
- VCF Benchmarks (for VCF)
- Custom Benchmarks (for both data sources)
- Regulatory Benchmarks (for both data sources)

Score Cards in the Compliance Page

In the **Security** > **Compliance** page, you can view scores for benchmarks that you have activated. Click a score card to view more information.

Table 1775: Compliance Page Score Card Options

Item	Description
Score card for the configured hardening guides, custom benchmark and management packs	Displays the compliance score, total compliant and non-compliant objects for the compliance standards you have configured.
Object Breakdown	Displays the number of compliant and non-compliant objects for the following types of objects: • vCenter • Host System • Virtual Machine • vSphere Distributed Port Group • vSphere Distributed Switch • vSAN Cache Disk • vSAN Capacity Disk • vSAN Cluster

Item	Description
Compliance Alert List	A list of alerts, grouped by time by default. You can either remove the grouping of the alerts, or group by criticality, definition, and object type. The alerts which caused the compliance violation are displayed in a table. You can sort the table by the following columns: • Alert ID • Criticality • Alert • Triggered On • Updated On Click **Actions** inside Compliance Alert list to edit the policies applied to the configuration guide. Click an alert to view more details. The **Alerts** tab in the **Inventory** page opens. Use the advanced quick filter to search for alerts. Click the drop-down arrow for more options to narrow your search.

Compliance Alerts

You use the compliance score card as an investigative tool when you evaluate the state of objects in your VCF platform, or when you research the root cause of a problem. If the score card indicates a problem, you can view the alerts to see details about the violation. Violated rules are based on the symptoms defined in the compliance alert.

> **Note:**
>
> Compliance Benchmarks are deprecated in VCF 9.1. Compliance is now managed by Security Posture Management.

The compliance alerts, which have the subtype named Compliance, include one or more symptoms that represent the compliance rules. Compliance alerts that are triggered appear in the **Symptoms** tab in an object when you navigate to the **Alerts** tab in the Inventory section of VCF Operations. Compliance alerts appear as violations to the standard, and the triggered symptoms appear as violated rules. The rules are the alert symptoms, and the symptom configuration identifies the incorrect value or configuration. If a rule symptom is triggered for any of the alerts in the standard, the triggered rule violates the standard and affects the score.

How To Configure Compliance Benchmarks

Configure VMware SDDC, VCF, Custom and Regulatory benchmarks from the Compliance page available when you navigate to **Protect** > **Compliance**. Unlike previous releases, you can now enable alert definitions in one of the active policies, from the Compliance page directly.

> **Note:**
>
> Compliance Benchmarks are deprecated in VCF 9.1 and is replaced by Security Posture Management.

Activate VCF Benchmarks

You can activate the VCF benchmarks to audit the compliance of the objects in your VCF platform. The products currently included for assessment are ESX, SDDC Manager, vCenter, vSAN and NSX.

> **Note:**
>
> Compliance Benchmarks are deprecated in VCF 9.1. Compliance is now managed by Security Posture Management.

For VCF Operations to measure compliance against these data sources, you must first configure them. See the relevant topic in Integrating Data Sources.

The Aria Operations CSA Compliance Pack is available as a Management Pack. Before you can enable the Aria Operations CSA Compliance Pack for VCF, you must install and activate the integration. Download the Management Pack

from the VMware Marketplace. For information on how to install a management pack, see the topic, Adding and Managing Management Packs from VMware Marketplace.

1. From the top menu, click **Protect** > **Compliance** to access the compliance page.
2. Select VMware Cloud Foundation from the carousel on the top of the page.
3. Do the following:
   a) To enable VCF Compliance based on the VCF Audit Guides, in the **VCF Benchmarks** section, click **Enable** in the **VCF Compliance based on the VCF Audit Guides** card.
   b) To enable VCF Operations CSA Compliance Pack for VCF, in the **Regulatory Benchmarks** section, click **Enable** in the **VCF Compliance based on the Cloud Security Alliance** card. Ensure that you have installed the Aria Operations CSA Compliance Pack.
4. Select the policy that you want to modify. When there are child policies, you can select a child policy and unselect a parent policy. VCF Operations modifies the selected policy and activates the alert definitions associated with the current scorecard.
5. Click **Enable** to confirm your selection.

VCF Operations starts to assess the objects based on the policy that you selected. To edit a policy, click **Edit** in the configuration guide pane and select a different policy.

Activate VMware SDDC Benchmarks

You can activate the VMware SDDC Benchmark to monitor objects for violation of vSphere Security Configuration Guide, vSAN Security Configuration Guide, NSX Security Configuration Guide. The score cards in the VMware SDDC Benchmark warn you when compliance alerts trigger on your vCenter instance, NSX-V objects, NSX objects, vSAN objects, ESX hosts, virtual machines, distributed port groups, or distributed virtual switches.

> **Note:**
>
> Compliance Benchmarks are deprecated in VCF 9.1. Compliance is now managed by Security Posture Management.

You must configure the data source for which you are enabling the VMware SDDC benchmarks before you proceed. See the relevant topic in Integrating Data Sources.

1. From the top menu, click **Protect** > **Compliance** to access the compliance page.
2. Select a data source from the carousel on the top of the page.
3. In the VMware SDDC Benchmarks section, click **Enable** under the vSphere Security Configuration Guide, vSAN Security Configuration Guide or NSX Security Configuration Guide card.

   The **Enable Policies** dialog box opens.
4. Select the policy that you want to modify. When there are child policies, you can select a child policy and unselect a parent policy. VCF Operations modifies the selected policy and activates the alert definitions associated with the current scorecard.
5. Click **Enable** to confirm your selection.

VCF Operations starts to assess the objects based on the policy that you selected. To edit a policy, click **Edit** in the configuration guide pane and select a different policy.

Create a New Custom Benchmark

You can create a custom compliance benchmark to ensure that objects comply with compliance alerts available in VCF Operations , or custom compliance alert definitions. When a compliance alert is triggered on your vCenter instance, ESX hosts, virtual machines, distributed port groups, or distributed switches, you investigate the compliance violation. You can add up to five custom compliance score cards.

Note:

Compliance Benchmarks are deprecated in VCF 9.1. Compliance is now managed by Security Posture Management.

To create a custom benchmark based on industry standard regulatory compliance requirements, you must first download and install the compliance management packs.

1. From the top menu, click **Protect** > **Compliance** to access the compliance page.
2. In the Custom Benchmarks section, click **Add Custom Compliance**.
   The **Add Custom Compliance** dialog box opens.
3. Select **Create a New Custom Benchmark**.
   a) In the Name and Description step, provide a name and description for the custom benchmark and click **Next**.
   b) In the Alert Definitions step, select the compliance alerts that you want to add to this custom compliance benchmark and click **Next**.
   c) In the Policies step, select the policies to activate compliance and click **Finish**.

The custom compliance which monitors alert definitions that you selected is available in the Custom Benchmarks section of the Compliance page. You can edit the alert definitions and policies at any time by clicking **Edit**.

Import or Export a Custom Benchmark

You can export custom benchmarks from any VCF Operations instance and import it to another instance. Reusing custom benchmarks saves you time and effort. You can modify an imported custom benchmark. Exported files are in the XML format. The XML file contains information about alert groups, alerts, and filters.

Note:

Compliance Benchmarks are deprecated in VCF 9.1. Compliance is now managed by Security Posture Management.

You must first export a XML file with the custom benchmarks from another instance of VCF Operations before importing the XML file to another instance.

1. From the top menu, click **Protect** > **Compliance** to access the compliance page.
2. Select a data source from the carousel on the top of the page.
3. In the Custom Benchmarks section, click **Add Custom Compliance**.
   The **Add Custom Compliance** dialog box opens.

   To import, do the following:
4. Select **Import An Existing Custom Benchmark**.
   a) In the Import Compliance Score card dialog box, select the Score card Definition XML file from your local computer. If the XML file contains cloned alerts from the VCF Operations instance that was used to export the file, the cloned alerts are also imported.
   b) VCF Operations displays a message to indicate if the XML file was successfully imported.
   c) If you see a message which indicates that there is a conflict between the data in the XML file and the custom benchmarks already defined, make a selection on how to handle a conflict.
   d) Click **Done**.

   To export, do the following:
5. To export an existing custom benchmark, click the score card to select the benchmark and select **Export** from the **Actions** menu.

The imported compliance benchmarks are available in the Custom Benchmarks section of the Compliance page. You can edit the alert definitions and policies at any time by clicking **Edit** from the **Actions** menu after clicking the score card.

Activate a Regulatory Benchmark

To enforce and report on the compliance of your vSphere objects, you activate the compliance pack that contains the policies for regulatory standards. Then, you select the policy to activate the appropriate regulatory alerts for your virtual machines.

> **Note:**
>
> Compliance Benchmarks are deprecated in VCF 9.1. Compliance is now managed by Security Posture Management.

Before you can enable some of the regulatory benchmarks, you may need to install the integration by following the steps in Adding and Managing Management Packs from VMware Marketplace after downloading the .PAK file from VMware Marketplace.

1. From the top menu, click **Protect** > **Compliance** to access the compliance page.
2. To activate any regulatory benchmark, click **Activate From Repository** on the required compliance pack.
3. Click **Activate** to complete the installation.
4. To activate the compliance pack policies, navigate to the **Compliance** homepage and click **Enable** on the installed compliance pack.
   The **Enable Policies** window opens.
5. Select the policies that you want to activate and click **Enable** to complete the process.

VCF Operations starts to assess the objects based on the regulatory benchmark that you installed.

Security Posture Management

Security Posture Management is where you measure compliance of supported VCF components. It offers a centralized portal for reviewing, investigating, and managing the compliance of supported VCF resources against established security benchmarks. It automates benchmark assessments across multiple components and presents actionable data for remediation.

Compliance Assessment and Reporting using Security Posture Management

Security Posture Management introduces a way to view, manage, and analyze compliance results of components in the VCF platform within VCF Operations. A new unified data grid interface displays the benchmark details and compliance score in a single view, so you do not have to navigate across multiple pages. You can now quickly locate non-compliant controls, understand their context, and take corrective actions. The Security Posture Management functionality deprecates the compliance functionality available in previous versions.

What Security Posture Management Offers

Viewing Results	You can see the compliance results in a data grid. The data grid displays compliance and non-compliance results together, enabling you to filter, sort, and search assessment data. The results are the outcome of evaluating components against the benchmark, which is categorized as compliant, non-compliant, or unknown. For more information, see Compliance Assessment Results and Remeditation.
Rule Browsing and Management	You can browse all benchmark rules that are associated with a compliance benchmark. • You can add values to rules where site specific settings, such as DNS server, login banner, etc. can be provided. • You can preview each rule. • You can tailor benchmark rules to align with specific organizational requirements. For more information, see Working with Benchmark Rules.

Compliance assessment and Non-compliance remediation	The compliance dashboard displays compliance and non-compliance status at the granularity of the compliance control across all or a selected subset of the inventory, providing sufficient detail regarding the compliant/non-compliant results. After running the assessement, you can view the compliance rules and compliance results for a designated compliance benchmark. You can run remediation on non-compliant objects. You can export assessment data and compliance results for external analysis and reporting purposes. • Export assessment results in CSV format for further processing or archival. • Generate compliance reports summarizing compliant and non-compliant items at the compliance control level for all or selected inventory. For more information, see Compliance Assessment Results and Remeditation.

What Security Posture Management Does

Compliance assessment is a core requirement for maintaining security, operational consistency, and regulatory adherence in VCF environments. The automated controls that are introduced in this release provide automated assessments of the native and custom benchmarks.

The main advantages are:

- Availability of out of the box benchmarks such as VMware Cloud Foundation Security Configuration and Hardening Guide (SCG), PCI DSS v4.0.1 for VCF and VCF 9 General Controls.
- A complete view of compliant and non-compliant items at the control level as per the selected policy.
- Remediation of non-compliant objects for supported list of rules.

How Compliance Assessment using Security Posture Management Works

Security Posture Management covers the following components, reflecting their status per benchmark rules.

- SDDC Manager
- Virtual Machines
- VMware Avi Load Balancer
- VMware Cloud Foundation Automation
- VMware Cloud Foundation Managed Service
- VMware Cloud Foundation Operations
- VMware Cloud Foundation Operations for networks
- VMware Cloud Foundation Operations Orchestrator
- VMware Cloud Proxy
- VMware ESX
- VMware HCX
- VMware NSX
- VMware NSX Edge
- VMware vCenter Server

VCF Operations measures compliance in the following way:

1. You enable a compliance benchmark by selecting a relevant policy. The assessment will run against all supported VCF objects associated with the policy linked to that benchmark. For more information on policies in see Policies.
2. VCF Operations assesses the environment against the controls that are defined in the selected benchmark.
3. You can see the following assessment results:
   - Which rules are non-compliant and compliant. A third state called Unknown is for those objects whose compliance cannot be acertained.
   - The associated inventory objects for each rule.
   - The current parameter values contributing to the assessment outcome.
4. You can filter or export the results.

You perform remediation by following these steps:

1. You run the assessment to measure compliance against a particular benchmark.

2. You view the compliance results.
3. You select the rules for which remediation is available. You can perform bulk remediation across all non-compliant rules or apply specific rules to a targeted selection of non-compliant objects.
4. You run the remediation.

Permissions to Access Security Posture Management

You must have a role with the required permissions to work with Security Posture Management. The permissions are available when you click **Operate** in the navigation bar at the top and in the left navigation pane, when you click **Administration** > **Control Panel**, and then when you click the **Roles** tab in the **Access Control** tile. The following options are available:

- Assess and Remediate
- Assess Only
- View

For more information, see Access Control: Roles Tab.

Setting the Compliance Assessment Schedule

VCF Operations assesses the environment against the controls that are defined in the selected benchmark as per the **Compliance Assessment Schedule** that you set in the Global Settings page. For more information, see List of Global Settings.

Working with Security Posture Management Benchmarks

The Security Posture Management page displays the out of the box benchmarks. These benchmarks are the starting point for compliance assessment. You can click a benchmark to view more information such as the control set in the benchmark.

The Security Posture Management Page

To access the Security Posture Management page, in the VCF Operations navigation bar at the top, click **Protect** and in the left navigation pane, click **Security Posture Management**. In the **Security Posture Management** page you can view and manage benchmarks, and view the compliance score for each benchmark.

The Security Posture Management page displays the following information:

- Benchmark Name
- Benchmark Description
- # Rule
- Per Component Rule Count
- Compliance Score

The status of any assessment that is currently in progress is displayed.

To view a list of components and their corresponding rule counts, click **View More** next to **Per Component Rule Count**.

Cloning a Benchmark

You can clone a benchmark, and all the rules that are part of the benchmark.

1. In the VCF Operations navigation bar at the top, click **Protect** and in the left navigation pane, click **Security Posture Management**.
2. In the vertical ellipses next to the benchmark that you want to clone, click **Clone Benchmark**.
3. In the Clone Benchmark dialog box which opens, provide the **Benchmark Name** and **Description**.
4. Click **SAVE**.

The cloned benchmark appears in the Security Posture Management page. You can delete a benchmark that you cloned. Default benchmarks (SCG, PCI DSS, General Controls) cannot be deleted. You click the benchmark to view and modify the rules. To enable the benchmark, see Enabling a Benchmark.

Enabling a Benchmark

To enable a benchmark, you must assign a policy. With policies, you control what data VCF Operations collects and reports on for specific objects in your environment. The scope of assessment for the benchmark is all the objects that are covered by the policy that you assign. For more information on policies in see Policies.

1. In the VCF Operations navigation bar at the top, click **Protect** and in the left navigation pane, click **Security Posture Management**.
2. In the vertical ellipses next to the benchmark that you want to enable, click **Enable Benchmark**.
3. In the Assign Policy dialog box which opens, select the policies which you want to assign to the benchmark.
4. Click **OK**.
5. Alternatively, click the benchmark name and go to the **View Control Set** tab in the rule page. Click **ENABLE BENCHMARK** and assign a policy to the benchmark.

Working with Benchmark Rules

The **View Control Set** section of the selected Benchmark displays compliance findings for the selected benchmark. Use this view to review rule-level details, and export the rules as a CSV.

1. In the VCF Operations navigation bar at the top, click **Protect** and in the left navigation pane, click **Security Posture Management**.
2. Click a benchmark name to go to that specific benchmark page.
3. Go to the **View Control Set** tab.
4. The following elements are displayed in the tab.

Option	Description
Rule information grid	View details of the rule in a grid which displays the **Rule**, **Severity**, **Component,** and **Assessed Condition**.

Option	Description
Edit Rule	Click the vertical ellipses next to a rule and then click **Edit Rule**. A rule cannot be modified while an assessment or remediation process is in progress. **Note:** Rules marked with an asterisk (*) require site-specific values. If you do not provide these values, the rule generates an error.
Filter rules	You can filter the rules by **Rule Name**, **Severity**, **Component,** and **Remediation Available**.
Export as CSV	To export the rules, click the **EXPORT AS CSV** button. Currently, the following benchmarks are provided out of the box: • VCF 9.x Security Configuration Guide v1.0

Option	Description
	• PCI DSS v4.0.1 for VCF 9 v1.0 • VCF 9 General Controls v1.0
Enable Benchmark	To enable the benchmark, if it is not already enabled, click the **ENABLE BENCHMARK** button. For more information, see Enabling a Benchmark
Run assessment	If the assessment has not already been run, click the **RUN ASSESSMENT** button.

5. If you have run an assessment against the benchmark, the banner on top of the page displays information about the results.

Finding More Content in Solutions Catalog

You can install a compliance content pack from the Solutions Catalog to measure objects against other compliance benchmarks that might be available time to time. The compliance content pack can be one which is available in VCF Operations, or Broadcom approved new compliance benchmarks you upload and install. After you install a benchmark, in order to run an assessment, you must first enable it.

1. In the VCF Operations navigation bar at the top, click **Protect** and in the left navigation pane, click **Security Posture Management**.
2. Click **BROWSE MORE BENCHMARKS**.
3. The **Solutions Catalog** tab in the **Integrations** page displays available management packs if your VCF Operations instance is online and connected to VCF Solutions Catalog.
4. Click the **DOWNLOAD** button available in the card of a compliance pack that you want to install. Alternatively, click the **UPLOAD** button to install a custom content pack.
5. Make an appropriate selection after reading the EULA.
6. After the content pack is downloaded, click the **Downloaded** tab and then the **INSTALL** button. You can check the installation status in the **Tasks** tab.

The benchmark that you installed is available in the Security Posture Management page. You can delete a benchmark that you installed. To enable the benchmark, see Enabling a Benchmark.

Running an Assessment

Assessments are run as per the Compliance Assessment Schedule that you set in the Global Settings page. Or, you can run an assessment on demand. Parallel assessments cannot be run on a same benchmarks. However, assessments can be run across different benchmarks at the same time.

1. In the VCF Operations navigation bar at the top, click **Protect** and in the left navigation pane, click **Security Posture Management**.
2. Click the vertical ellipses against a benchmark and select **Run Assessment**.
3. Alternatively, click the benchmark rule and go to the **View Control Set** tab in the rule page. Click **RUN ASSESSMENT**.
4. The results of the assessment are available in the **View Result** tab after the assessment is completed. You can view the results by navigating to the compliance score link from the benchmark grid or navigating to the benchmark.

Compliance Assessment Results and Remeditation

The assessment results page includes the current parameter value for each control. This helps users understand exactly which configuration values contributed to the result. Configuration value for compliant objects are displayed as **N/A**. You can export the assessment results CSV and PDF formats for audit and reporting.

Where You Find the Compliance Assessment Results

In the VCF Operations navigation bar at the top, click **Protect** and in the left navigation pane, click **Security Posture Management**. Click the name of a benchmark and then go to the **View Results** tab.

Understanding the Results Page

VCF Operations provides a dashboard view for assessing and managing the security posture of VCF environments. On the page, you can review, investigate, and manage the compliance of VCF components.

Benchmark Summary	Overview of the selected benchmark and its purpose.
Overview - Graphs and Charts	The **Overall Compliance Score** is a percentage-based metric derived by dividing the total count of compliant results by the total number of assessed results, then multiplying by 100. **Result by Component** A stacked bar chart illustrating the distribution of compliant, non-compliant, and unknown results categorized by each assessed VCF object type. Each bar shows the distribution of: • Compliant results • Non-compliant results • Unknown results **Non-compliant Results by Severity** This bar chart provides a breakdown of non-compliant findings, exclusively grouped by their assigned severity levels, **Critical**, **Immediate**, and **Warning** and **Info**, across all assessed object types You can hover over or click each bar segment for details on compliant, non-compliant, and unknown counts per component.
Filters	Filter options by **Rule Name**, **Severity**, **Component**, **Remidiation Available**.
Results Table	Detailed list of rules, severity, component, assessed condition, and object counts (**Non-Compliant**, **Compliant**, and **Unknown**). Objects marked as **Unknown** indicate that the assessment could not be successfully executed. You can export the results to a CSV file for detailed troubleshooting information.
Export & Reporting	Click **EXPORT AS CSV** to generate a CSV file. The CSV file provides detailed report of the assessment against each rule. Alternatively, click **GENERATE REPORT** to generate a PDF file which contains the Rule Name, Component Type, Severity, Assessed Condition, Non-Compliant Objects, Compliant Objects and Unknown Objects.
Remediate	Some of the rules in the results page offer remeditation. You can select the checkbox next to these rules. When you select the checkbox and click the **REMEDIATE** button, VCF Operations automatically remediates the non-compliant objects. The status of the remediation job is displayed as banner on top of the page. You can choose to remediate all objects or select objects to remediate. After the remeditation is complete, you can download a report in CSV format. You must rerun the assessment after the remeditation to see updates.

Granular Assessment

For every rule, you see a count of the following:

- Non-compliant object count
- Compliant object count
- Unknown object count

You can perform the following actions:

- Click the count to see more information about the assessment results of these objects.
- Click the chevron next to a rule to view the list of non-compliant, compliant, and unknown objects. Click **VIEW RULE** to see details about the rule.

Audit Records and Audit Trail

The Audit Records page provides a centralized location where you can examine the diverse audit records that are generated across the supported VCF components. Each audit record has information which helps you analyze the user actions in your VCF environment.

Your organization may be required to provide audit data to support both internal and external audit reviews. Audit cycles are shortened by audit records, because data is collected from various components, and presented in a unified interface. For the supported audit records, see Audit Record Coverage.

Using Audit Trail, you can get complete traceability of the supported user actions in the VCF environment, so that any suspicious or unauthorized activity can be dealt with in a timely manner.

Viewing Audit Records

Audit records help you track user actions and changes (including security and compliance related modifications) to ensure operational robustness and traceability in your VCF environment. Use the Audit Records page in VCF Operations to review, filter, and export logged actions that are performed by users on various VCF components. You can also establish lateral movement from one VCF component to another. The page supports searching within a selected time range and offers filtering capabilities by severity, result, component, object, and more.

Supported VCF Components for Audit Records

The following VCF components use standardized audit records:

- ESX
- NSX
- VMware Management Services Platform
- VCF Operations
- vCenter
- VCF Operations for networks
- Identity Broker
- VMware vSphere Kubernetes Service
- log management

Prerequisites for Viewing Audit Records

You must configure Log collection from the supported VCF components to see audit records. Audit records and audit trail are only available to the user with certain roles. For more information, see Roles and Privileges in VCF Operations.

To configure the Log collection, see, Managing Collection from Log Sources. Click the **Check Log Collection Status** link in the Audit Records page to check if the supported VCF components are configured for log collection.

The Audit Records Page

The Audit Records page in VCF Operations is where you review detailed audit records that are generated by supported VCF components. Each record provides insights into user activities, helping you analyze actions that are performed within your VCF environment.

Where You Find Audit Records

After you log in to VCF Operations, from the navigation bar at the top, click **Protect** and in the left navigation pane, click **Audit Records**. A list of audit records is displayed in a table in the right pane on the page for a given time range. You can change the time range and filter the audit records by using the filters on the left pane. Click a record entry in the right pane to see more details.

Working with Audit Records

On the Audit Records page, you can work with the following elements:

Time Range selector	Available on the top of the page. Helps you limit the displayed results to a specific period. The default is 24 hours.
Filters Panel	Available in the left pane. Provides criteria for narrowing displayed results by record attributes, including severity. The following filters are available: • **Result**. Filter by success or failure.

- **Severity**. Filter by the audit record severity. For example, warning and info.
- **Component Type**. Filter by the VCF components.
- **Record Category**. Filter by the record categories. The current standardized categories are Account, Auth, Certificate, Security, and System.
- **Object Type**. Filter by the object type.
- **Record ID**. Filter by unique ID per component. Refer to the following topic for more information record IDs. Audit Record Coverage.
- **Component Name**. Filter by a specific instance of a VCF component. Could be the IP address or FQDN of the component.
- **Subject**. Filter by the user that performed the action.
- **Changed From**. Filter by the change of state resulting from the action performed by a user.
- **Changed To**. Filter by the change of state resulting from the action performed by a user.
- **Object Name**. Filter by the precise object on which the action was performed.

Record Table The Records table displays the audit record information. Click **Manage Columns** below the records table to add, remove visible fields in the grid.

Exporting the Audit Records

Click the **Export** button to download audit records for offline analysis. A zip file containing a CSV file with audit records is downloaded to the local computer from where you have logged in to VCF Operations.

Audit Record Coverage

Download the linked file to see the audit records which VCF Operations collects from different VCF components.

To view details about the audit record coverage, download the `.xlsx` file from here.

The Audit Trail Page

The Audit Trail page provides a chronological timeline of user-initiated activity in VCF components, enabling you to analyze, filter, and report on supported list of audit records. The dashboard supports visual analytics for audit results and drill-down into individual time slices.

Where you find the Audit Trail Page

After you log in to VCF Operations, from the navigation bar at the top, click **Protect** and in the left navigation pane, click **Audit Records**. Click the **LAUNCH AUDIT TRAIL** button. Click **ANALYZE** after you provide the **Time Range**, **Subjects**, or **Record ID** as required to scope the resulting trail of user activity.

The Audit Trail Page

Use the Audit Trail to track the sequence and outcome of user activity over a defined time range. The page facilitates detection and investigation of anomalous activity via charts, record timelines, and export features.

On the Audit Trail results page, the **Overview** section displays the audit trail summary and audit records distribution which is based on the provided scoping parameters. The trend chart in the **Overview** section plots Success vs. Failure counts by 15-minute time slices. You can see a high-level summary by **Severity**, **Component**, and **Subjects**.

You can drill down in the **Record Timeline** to expand record details by 15-minute time slices. Use the filters from the left panel to narrow down specific record types and components. The following filters are available:

Filters Panel The filters panel provides criteria for narrowing displayed results by record attributes, including severity. The following filters are available:

- **Result**. Filter by success or failure.
- **Severity**. Filter by the audit record severity. For example, warning and info.
- **Component Type**. Filter by the VCF components.
- **Record Category**. Filter by the record categories. The current standardized.
- **Object Type**. Filter by the object type.

- **Component Name**. Filter by a specific instance of a VCF component. Could be the IP address or FQDN of the component.
- categories are Account, Auth, Certificate, Security, and System.
- **Changed From**. Filter by the change of state resulting from the action performed by a user.
- **Changed To**. Filter by the change of state resulting from the action performed by a user.
- **Object Name**. Filter by the precise object on which the action was performed.

The **Records Timeline** displays the audit record information in 15 minute time slices. You can select one or more time slice and can export them as a CSV file.

Note:

For any given time slice, only the most recent 10,000 entries are shown for that slice.